

COMPLIANCE GAP ANALYSIS REPORT

GDPR Readiness Assessment — General Data Protection Regulation (EU) 2016/679

Company	TechStartup Pvt Ltd
Policy Analyzed	Privacy Policy v2.1 (August 2025)
Standard	GDPR — All 99 Articles, 11 Chapters
Analysis Date	6 August 2025
Generated By	ComplianceIQ Engine v1.0 — onetab.ai
Analyzed By	Agentic RAG Pipeline (4-Agent System)



Fully Met	12
Partially Met	9
Not Met	7
Conflicting	2
Total Requirements	30

RISK LEVEL: MEDIUM RISK — Action recommended

Max fine exposure: €20M or 4% annual revenue

Chapter-by-Chapter Breakdown

Ch	Chapter Name	Articles	Score	Status
1	General Provisions	Art. 1–4	—	Not Assessed
2	Principles	Art. 5–11	53.85%	Needs Improvement
3	Rights of the Data Subject	Art. 12–23	65.0%	Needs Improvement
4	Controller and Processor	Art. 24–43	42.86%	High Risk
5	Third Country Transfers	Art. 44–49	—	Not Assessed
6	Supervisory Authorities	Art. 51–59	—	Not Assessed
7	Cooperation & Consistency	Art. 60–76	—	Not Assessed
8	Remedies, Liability & Penalties	Art. 77–84	—	Not Assessed
9	Special Situations	Art. 85–91	—	Not Assessed
10	Delegated Acts	Art. 92–93	—	Not Assessed
11	Final Provisions	Art. 94–99	—	Not Assessed

This chapter is a critical gap area as it covers the fundamental principles of data processing, including lawfulness, fairness, and transparency, which are heavily scrutinized by regulators to ensure organizations are handling personal data in a lawful and ethical manner. Failure to fully meet these principles can lead to significant compliance risks and potential fines.

This chapter is a critical gap area as it covers the rights of data subjects, including access, rectification, and erasure, which are heavily scrutinized by regulators to ensure compliance with GDPR principles. Failure to fully meet these requirements can lead to significant fines and reputational damage, making it essential to address the partially met and unmet criteria.

This chapter is a critical gap area as it covers the responsibilities of controllers and processors, which are heavily scrutinized by regulators to ensure compliance with data protection principles. Effective implementation of these articles is essential to prevent data breaches and fines, and thus, it is crucial to address the partially met and unmet requirements in this area.

Detailed Gap Analysis

5.1.a.1 · Art. 5(1)(a)

Fully Met Confidence: High (0.96)

GDPR Requires:

Personal data must be processed lawfully, fairly, and transparently.

Your Policy:

We process personal information lawfully, fairly and transparently.

Fix Required:

No action required.

5.1.b.1 · Art. 5(1)(b)

Fully Met Confidence: High (0.94)

GDPR Requires:

Data must be collected for specified, explicit, legitimate purposes and not further processed incompatibly.

Your Policy:

Personal information is collected for specified business purposes and is not used for unrelated purposes without appropriate authorization.

Fix Required:

No action required.

5.1.c.1 · Art. 5(1)(c)

Partially Met Confidence: High (0.91)

GDPR Requires:

Data collected must be adequate, relevant, and limited to what is necessary (data minimisation).

Your Policy:

We collect only information that is necessary to provide our services.

Analysis:

The policy evidence partially meets the requirement for data minimisation by stating that only necessary information is collected, but it lacks objective criteria or a documented process for determining data necessity. This gap indicates a need for more specific guidelines on what data is considered necessary. The absence of such criteria may lead to overcollection of data.

Fix Required:

Add an appendix detailing the objective criteria used to determine the necessity of collected data.

5.1.d.1 · Art. 5(1)(d)

Not Met Confidence: High (0.88)

GDPR Requires:

Personal data must be accurate and kept up to date.

Your Policy:

No matching evidence found in policy.

Analysis:

The policy does not meet the GDPR requirement for ensuring personal data accuracy and up-to-dateness, as no evidence or mechanism for maintaining accuracy is provided. This significant gap suggests a lack of attention to data quality. Without a mechanism for ensuring accuracy, the data collected may become outdated or incorrect.

Fix Required:

Establish and document a regular data validation process to ensure personal data accuracy.

5.1.e.1 · Art. 5(1)(e)

Partially Met Confidence: High (0.91)

GDPR Requires:

Data must be kept in identifiable form no longer than necessary (storage limitation).

Your Policy:

Personal information is retained for as long as necessary to fulfill the purposes for which it was collected.

Analysis:

The policy partially satisfies the storage limitation principle by stating that personal information is retained as long as necessary, but it fails to provide a specific retention period or objective criteria for determining retention. This omission makes it difficult to assess compliance with the principle. The lack of clear retention criteria may lead to indefinite data storage.

Fix Required:

Define and document specific data retention periods or criteria for each type of personal data collected.

5.1.f.1 · Art. 5(1)(f)

Fully Met Confidence: High (0.95)

GDPR Requires:

Data must be processed with appropriate security, integrity and confidentiality.

Your Policy:

We implement appropriate technical and organizational safeguards to protect personal information.

Fix Required:

No action required.

6.1.a.1 · Art. 6(1)(a)

Fully Met Confidence: High (0.93)

GDPR Requires:

Processing requires a valid legal basis, e.g. freely given consent.

Your Policy:

Where required, we obtain consent before processing personal information.

Fix Required:

No action required.

6.1.b.1 · Art. 6(1)(b)

Partially Met Confidence: High (0.89)

GDPR Requires:

Processing may be based on necessity for performance of a contract.

Your Policy:

Certain information may be processed when necessary to perform our contractual obligations.

Analysis:

The policy partially meets the requirement for processing based on necessity for performance of a contract, as it mentions contractual obligations but does not specify which processing activities are based on this legal basis. This gap indicates a need for clearer mapping between legal bases and processing activities. Without such mapping, it is unclear which activities are legally justified.

Fix Required:

Create a table or annex mapping specific processing activities to the legal basis of contractual necessity.

6.1.c.1 · Art. 6(1)(c)

Not Met Confidence: High (0.86)

GDPR Requires:

Processing may be based on compliance with a legal obligation.

Your Policy:

No matching evidence found in policy.

Analysis:

The policy does not meet the requirement for processing based on compliance with a legal obligation, as no provision addressing this basis is identified. This significant gap suggests a lack of consideration for legal obligations in data processing. The absence of such provisions may indicate non-compliance with legal requirements.

Fix Required:

Add a section outlining the legal obligations that justify data processing and specify which processing activities are based on legal compliance.

7.1.1 · Art. 7(1)

Fully Met Confidence: High (0.97)

GDPR Requires:

Consent requests must be clearly distinguishable, intelligible and easily accessible.

Your Policy:

Consent requests are presented separately from other terms and may be withdrawn at any time.

Fix Required:

No action required.

7.1.2 · Art. 7(3)

Partially Met Confidence: High (0.9)

GDPR Requires:

Data subject must be able to withdraw consent at any time, as easily as it was given.

Your Policy:

Users may withdraw consent by contacting our privacy team.

Analysis:

The policy partially satisfies the requirement for consent withdrawal, as it allows users to withdraw consent but does not ensure that this process is as easy as giving consent. This gap indicates a need for simplification of the withdrawal process. The current process may deter users from withdrawing consent.

Fix Required:

Implement an automated consent withdrawal mechanism that is as straightforward as the initial consent process.

8.1.1 · Art. 8(1)

Not Met Confidence: High (0.84)

GDPR Requires:

Where a child's consent applies, verifiable parental/guardian authorization is required.

Your Policy:

No matching evidence found in policy.

Analysis:

The policy does not meet the requirement for verifiable parental or guardian authorization for children's consent, as no mechanism for obtaining or verifying such authorization is specified. This significant gap suggests a lack of protection for children's data. The absence of parental authorization mechanisms may lead to unauthorized processing of children's data.

Fix Required:

Develop and document a process for obtaining and verifying parental or guardian consent for minors, including technical measures to verify parental identity.

9.1.1 · Art. 9(1)

Conflicting Confidence: High (0.87)

GDPR Requires:

Processing of special categories of personal data (health, biometric, etc.) is prohibited unless an exemption applies.

Your Policy:

We do not intentionally collect sensitive personal information.

Analysis:

The policy's stance on processing special categories of personal data is conflicting, stating that sensitive information is not intentionally collected but containing contradictory statements. This confusion indicates a need for clarity on the collection and processing of special categories of data. The current policy may lead to unintentional collection or processing of sensitive data.

Fix Required:

Revise the policy to clearly state whether special categories of personal data are collected and, if so, under what exemptions and with what safeguards.

12.1.1 · Art. 12(1)

Fully Met Confidence: High (0.95)

GDPR Requires:

Information must be provided in a concise, transparent, intelligible, and easily accessible form, using plain language.

Your Policy:

This policy is written in clear and accessible language.

Fix Required:

No action required.

13.1.a.1 · Art. 13(1)(a)

Fully Met Confidence: High (0.96)

GDPR Requires:

The identity and contact details of the controller must be provided.

Your Policy:

ABC Ltd. is the controller responsible for your personal information. Our contact details are provided below.

Fix Required:

No action required.

13.1.c.1 · Art. 13(1)(c)

Partially Met Confidence: High (0.92)

GDPR Requires:

The purposes and legal basis of processing must be disclosed for each purpose.

Your Policy:

We use personal information to provide services, communicate with customers, and improve our products.

Analysis:

The policy evidence partially satisfies the requirement as it mentions the purposes of processing but fails to clearly map the legal basis to each purpose, leaving a gap in transparency. The noted gap highlights the need for explicit disclosure of the legal basis for each purpose. To fully meet the requirement, the policy must explicitly state the legal basis for each processing purpose.

Fix Required:

Add a section explicitly mapping the legal basis to each processing purpose, ensuring transparency and compliance with Art. 13(1)(c).

14.1.1 · Art. 14(1)

Not Met Confidence: High (0.83)

GDPR Requires:

Where data is not obtained from the subject, equivalent transparency information must be provided.

Your Policy:

No matching evidence found in policy.

Analysis:

The policy evidence does not satisfy the requirement as it lacks information on providing transparency when data is not obtained from the subject, resulting in a significant gap. The noted gap emphasizes the absence of a third-party data notification process. To meet the requirement, the policy must include a process for providing equivalent transparency information when data is sourced from third parties.

Fix Required:

Develop and document a third-party data notification process, ensuring equivalent transparency information is provided as required by Art. 14(1).

15.1.1 · Art. 15(1)

Fully Met Confidence: High (0.94)

GDPR Requires:

Data subject has the right to obtain confirmation and access to their personal data.

Your Policy:

You may request access to the personal information we hold about you by submitting a request to our privacy team.

Fix Required:

No action required.

16.1.1 · Art. 16

Fully Met Confidence: High (0.95)

GDPR Requires:

Data subject has the right to rectification of inaccurate personal data.

Your Policy:

You may request correction of inaccurate or incomplete personal information.

Fix Required:

No action required.

17.1.1 · Art. 17(1)

Partially Met Confidence: High (0.93)

GDPR Requires:

Data subject has the right to erasure ('right to be forgotten') without undue delay.

Your Policy:

You may request deletion of your account and associated personal information.

Analysis:

The policy evidence partially meets the requirement as it allows for the deletion of accounts and associated personal information but does not clearly outline the exceptions and conditions for erasure. The noted gap indicates a need for clearer policy language regarding the right to erasure. To fully comply, the policy must explicitly describe the applicable exceptions and conditions for erasure as per Art. 17(1).

Fix Required:

Update the policy to clearly describe the exceptions and conditions under which the right to erasure applies, ensuring compliance with Art. 17(1).

18.1.1 · Art. 18(1)

Not Met Confidence: High (0.89)

GDPR Requires:

Data subject has the right to obtain restriction of processing in specified circumstances.

Your Policy:

No matching evidence found in policy.

Analysis:

The policy evidence does not meet the requirement as it fails to address the right to obtain restriction of processing, leaving a significant gap. The noted gap highlights the absence of any mention of restriction of processing in the policy. To satisfy the requirement, the policy must be updated to include the circumstances under which data subjects can obtain restriction of processing.

Fix Required:

Add a section addressing the right to restriction of processing, outlining the specified circumstances under which data subjects can exercise this right as required by Art. 18(1).

20.1.1 · Art. 20(1)**Partially Met** Confidence: High (0.88)**GDPR Requires:**

Data subject has the right to receive their data in a structured, machine-readable format (portability).

Your Policy:

Users may request a copy of the personal information associated with their account.

Analysis:

The policy evidence partially satisfies the requirement as it allows users to request a copy of their personal information but lacks specificity on the format and transmission requirements for data portability. The noted gap emphasizes the need for clearer guidelines on data portability. To fully meet the requirement, the policy must specify that the data will be provided in a structured, machine-readable format.

Fix Required:

Specify that personal data will be provided in a structured, machine-readable format upon request, ensuring compliance with the data portability requirements of Art. 20(1).

21.1.1 · Art. 21(1)**Fully Met** Confidence: High (0.93)**GDPR Requires:**

Data subject has the right to object to processing based on legitimate interests, at any time.

Your Policy:

You may object to certain uses of your personal information by contacting our privacy team.

Fix Required:

No action required.

22.1.1 · Art. 22(1)**Conflicting** Confidence: High (0.86)**GDPR Requires:**

Data subject has the right not to be subject to a decision based solely on automated processing.

Your Policy:

We do not make decisions about individuals solely through automated means.

Analysis:

The policy evidence partially satisfies the requirement as it states that decisions about individuals are not made solely through automated means, but the noted gap indicates inconsistent statements regarding automated decision-making, which may lead to confusion. The policy needs clarification to ensure consistency. The requirement is not fully met due to the inconsistency.

Fix Required:

Revise the policy to consistently state the approach to automated decision-making and ensure it aligns with GDPR requirements.

25.1.1 · Art. 25(1)**Partially Met** Confidence: High (0.9)**GDPR Requires:**

Controller must implement data protection by design and by default.

Your Policy:

Privacy and security considerations are taken into account when developing new systems.

Analysis:

The policy evidence partially meets the requirement as it mentions considering privacy and security when developing new systems, but it lacks a documented process or controls for embedding data protection into system design, as noted in the gap. This indicates an incomplete implementation of data protection by design and by default.

Fix Required:

Develop and document a process for embedding data protection into system design and by default.

30.1.1 · Art. 30(1)**Not Met** Confidence: High (0.85)**GDPR Requires:**

Controller must maintain a record of processing activities.

Your Policy:

No matching evidence found in policy.

Analysis:

The policy evidence does not satisfy the requirement as there is no matching evidence found in the policy regarding maintaining a record of processing activities, which is a significant gap. This indicates a lack of compliance with the GDPR requirement.

Fix Required:

Establish and document a record-of-processing-activities process to maintain records as required by GDPR.

32.1.1 · Art. 32(1)

Fully Met Confidence: High (0.97)

GDPR Requires:

Controller must implement appropriate technical/organizational security measures.

Your Policy:

Personal information is protected using encryption, access controls, monitoring and other appropriate security measures.

Fix Required:

No action required.

33.1.1 · Art. 33(1)

Partially Met Confidence: High (0.92)

GDPR Requires:

A personal data breach must be notified to the supervisory authority within 72 hours.

Your Policy:

Personal data breaches must be reported to the privacy team promptly for assessment and response.

Analysis:

The policy evidence partially meets the requirement as it mentions reporting personal data breaches to the privacy team, but it does not explicitly state the applicable supervisory authority notification deadline, as noted in the gap. This partial compliance may lead to delays or non-compliance with the 72-hour notification requirement.

Fix Required:

Update the policy to explicitly state the 72-hour deadline for notifying the supervisory authority in case of a personal data breach.

35.1.1 · Art. 35(1)

Fully Met Confidence: High (0.94)

GDPR Requires:

A Data Protection Impact Assessment (DPIA) is required for high-risk processing.

Your Policy:

High-risk processing activities undergo a privacy impact assessment before implementation.

Fix Required:

No action required.

36.1.1 · Art. 36(1)

Not Met Confidence: High (0.82)

GDPR Requires:

Prior consultation with the supervisory authority is required where a DPIA indicates high residual risk.

Your Policy:

No matching evidence found in policy.

Analysis:

The policy evidence does not satisfy the requirement as there is no matching evidence found in the policy regarding prior consultation with the supervisory authority when a DPIA indicates high residual risk, indicating a significant gap. This lack of procedure may lead to non-compliance with GDPR requirements.

Fix Required:

Develop and document a prior consultation procedure with the supervisory authority for cases where a DPIA indicates high residual risk.

Priority Action Plan

P1 — CRITICAL PRIORITY · 9 items

#	Sub-ID	GDPR Article	Action Required	Current Status
1	5.1.d.1	Art. 5(1)(d)	Establish and document a regular data validation process to ensure personal data accuracy.	Not Met
2	6.1.c.1	Art. 6(1)(c)	Add a section outlining the legal obligations that justify data processing and specify which processing activities are based on legal compliance.	Not Met
3	8.1.1	Art. 8(1)	Develop and document a process for obtaining and verifying parental or guardian consent for minors, including technical measures to verify parental identity.	Not Met
4	9.1.1	Art. 9(1)	Revise the policy to clearly state whether special categories of personal data are collected and, if so, under what exemptions and with what safeguards.	Conflicting
5	14.1.1	Art. 14(1)	Develop and document a third-party data notification process, ensuring equivalent transparency information is provided as required by Art. 14(1).	Not Met
6	18.1.1	Art. 18(1)	Add a section addressing the right to restriction of processing, outlining the specified circumstances under which data subjects can exercise this right as required by Art. 18(1).	Not Met
7	22.1.1	Art. 22(1)	Revise the policy to consistently state the approach to automated decision-making and ensure it aligns with GDPR requirements.	Conflicting
8	30.1.1	Art. 30(1)	Establish and document a record-of-processing-activities process to maintain records as required by GDPR.	Not Met
9	36.1.1	Art. 36(1)	Develop and document a prior consultation procedure with the supervisory authority for cases where a DPIA indicates high residual risk.	Not Met

P2 — HIGH PRIORITY · 9 items

#	Sub-ID	GDPR Article	Action Required	Current Status
1	5.1.c.1	Art. 5(1)(c)	Add an appendix detailing the objective criteria used to determine the necessity of collected data.	Partially Met
2	5.1.e.1	Art. 5(1)(e)	Define and document specific data retention periods or criteria for each type of personal data collected.	Partially Met
3	6.1.b.1	Art. 6(1)(b)	Create a table or annex mapping specific processing activities to the legal basis of contractual necessity.	Partially Met
4	7.1.2	Art. 7(3)	Implement an automated consent withdrawal mechanism that is as straightforward as the initial consent process.	Partially Met
5	13.1.c.1	Art. 13(1)(c)	Add a section explicitly mapping the legal basis to each processing purpose, ensuring transparency and compliance with Art. 13(1)(c).	Partially Met
6	17.1.1	Art. 17(1)	Update the policy to clearly describe the exceptions and conditions under which the right to erasure applies, ensuring compliance with Art. 17(1).	Partially Met
7	20.1.1	Art. 20(1)	Specify that personal data will be provided in a structured, machine-readable format upon request, ensuring compliance with the data portability requirements of Art. 20(1).	Partially Met
8	25.1.1	Art. 25(1)	Develop and document a process for embedding data protection into system design and by default.	Partially Met
9	33.1.1	Art. 33(1)	Update the policy to explicitly state the 72-hour deadline for notifying the supervisory authority in case of a personal data breach.	Partially Met

Executive Summary

TechStartup Pvt Ltd has an overall GDPR compliance score of 55.0%, indicating a medium risk level that necessitates action. The company's strongest area is Chapter 3, Rights of the Data Subject, with a score of 65.0%. However, critical gaps exist in several chapters, including the lack of a regular data validation process, insufficient documentation of legal obligations for data processing, and the absence of a process for obtaining parental consent for minors. These gaps, particularly those related to data accuracy, legal compliance, and special categories of personal data, pose significant legal risks. The urgency of remediation is high, as these gaps can lead to non-compliance with GDPR, resulting in potential legal and financial consequences. It is essential for the company to address these critical gaps, particularly those related to Articles 5, 6, 8, 9, 14, 18, 22, 30, and 36, to ensure GDPR compliance and mitigate potential risks.

DISCLAIMER: This report was generated by ComplianceIQ, an AI-powered compliance analysis tool developed by onetab.ai. It is intended for informational purposes only and does not constitute legal advice. ComplianceIQ uses Agentic RAG technology to map policy text against regulatory requirements and may not capture all nuances of legal interpretation. Organizations should consult qualified legal counsel before making compliance decisions. Confidence scores indicate retrieval quality, not legal certainty.